



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CLOP Ransomware Gang Threat Actor Profile

Threat Actor Profile

Classification	TLP:CLEAR
Published	2026-08-12
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Actor Profile

TLP:CLEAR | Lost Boys Cyber | CLOP Ransomware Gang Threat Actor Profile - Threat Actor Profile

Published: 2026-08-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Key Judgments
3. Actor Identity and Aliases
4. Motivation, Culture, and Operating Model
5. Historical Timeline
6. Victimology and Targeting
7. Mindset and Analyst Bottom Line
8. Tactics, Techniques, and Procedures
 - 8.1. Initial Access
 - 8.2. Execution
 - 8.3. Persistence and Privilege
 - 8.4. Defense Evasion
 - 8.5. Discovery and Collection
 - 8.6. Command and Control / Exfiltration
 - 8.7. Impact
9. Tooling and Malware
10. Infrastructure and Indicators
11. Detection Engineering
 - 11.1. Sigma: MOVEit LEMURLOOT Webshell File Artifact
 - 11.2. Sigma: MOVEit X-siLock Header Interaction
 - 11.3. Sigma: Cleo Autorun Exploitation and Post-Exploitation
 - 11.4. Sigma: Ransomware Note or CLOP Extension
 - 11.5. YARA: CLOP Ransomware/Ransom Note Strings
 - 11.6. YARA: MOVEit LEMURLOOT ASP.NET Webshell Strings
12. Microsoft Defender XDR / KQL Hunt Queries
 - 1.1. MOVEit LEMURLOOT file creation
 - 2.1. X-siLock header activity in proxy/WAF/web logs
 - 3.1. Suspicious child processes from MFT/application servers
 - 4.1. Cleo exploitation via autorun and PowerShell/JAR retrieval
 - 5.1. CLOP ransomware artifact hunt
 - 6.1. Edge application bulk exfiltration candidate hunt
7. Splunk SPL Hunt Queries
 - 1.1. MOVEit webshell and X-siLock headers
 - 2.1. Suspicious child process from web/MFT services
 - 3.1. Cleo autorun artifacts
 - 4.1. CLOP encryption artifacts
5. Suricata / Network Detection Starting Points
 - 5.1. MOVEit LEMURLOOT X-siLock Header

5.2. Suspicious MOVEit human2.aspx Request

6. Threat Hunting Playbooks

6.1. Hunt 1: Exposed MFT compromise triage

6.2. Hunt 2: Data theft without ransomware deployment

6.3. Hunt 3: Classic TA505/FIN11 intrusion chain leading to CLOP

6.4. Hunt 4: Cleo exploitation-focused hunt

6.5. Hunt 5: Oracle EBS extortion campaign review

7. Priority Defensive Controls

8. Incident Response Guidance

9. Attribution Caveats

10. Source Review and Reliability

11. References

Lost Boys Cyber Threat Actor Profile: CLOP / CL0P Ransomware Gang

Classification: TLP:CLEAR Published: 2026-08-12 Version: 1.0 Author: Lost Boys Cyber Report Type: Threat Actor Profile

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

1. Executive Summary

CLOP, also written CL0P, Clop, or Cl0p, is a financially motivated ransomware and data-extortion brand most consistently associated in public reporting with the TA505 / FIN11 cybercrime ecosystem. The group emerged as a CryptoMix-derived ransomware operation in 2019, but its operational center of gravity shifted from classic file encryption toward large-scale data theft and extortion after the 2020-2021 Accellion FTA campaign.

CLOP is most dangerous when exploiting enterprise file-transfer and business application platforms at scale. Its highest-impact campaigns include Accellion FTA exploitation in 2020-2021, Fortra GoAnywhere MFT exploitation in early 2023, Progress MOVEit Transfer exploitation in May-June 2023, Cleo Harmony/VLTrader/LexiCom exploitation in late 2024, and an Oracle E-Business Suite extortion campaign reported by Google Threat Intelligence Group in 2025. The recurring pattern is opportunistic mass exploitation of internet-facing systems, rapid data staging/exfiltration, delayed extortion, public pressure through the CL0P leak site, and, increasingly, no ransomware encryption at all.

Analytic judgment: CLOP should be treated less as a single static malware family and more as a durable extortion brand connected to a broader Russian-speaking eCrime ecosystem. Attribution to FIN11/TA505 is strong for several historic and MFT-focused campaigns, but public sources also warn that the CLOP data leak site and brand may be used by multiple related or partnered actor clusters. Defenders should prioritize exposed MFT/business-app inventory, exploit logging, webshell detection, database-access anomaly detection, data egress telemetry, and executive extortion preparedness.

2. Key Judgments

Judgment	Confidence	Evidence
CLOP is financially motivated and Russian-speaking/CIS-aligned rather than ideological.	High	CISA/FBI and Canadian Centre reporting describe TA505/CL0P as financially motivated; Canadian Centre assesses likely CIS base.
CLOP has shifted from encryption-led ransomware to data-theft extortion, especially against MFT platforms.	High	CISA notes recent campaigns beginning 2021 relied mostly on exfiltration over encryption; Google/Mandiant describe mass data-theft campaigns without immediate ransomware deployment.
FIN11/TA505 overlap is real but should not be treated as a universal synonym for every CLOP-branded event.	Medium-High	Mandiant merged MOVEit UNC4857 into FIN11 based on targeting, infrastructure, certificate, and DLS overlaps, but separately cautions FIN11 and TA505 should not be used interchangeably and later notes CL0P branding may involve more than one actor cluster.
CLOP prefers high-leverage third-party data stores and file-transfer systems because one zero-day can expose many victims and produce extortion scale.	High	Accellion, GoAnywhere, MOVEit, Cleo, and Oracle EBS campaigns all followed mass exploitation/data theft models.
The primary defensive gap is usually lack of visibility on edge application logs,	High	LEMURLOOT and DEWMODE behavior centers on webshell access,

application databases, and outbound bulk transfer from MFT/business-app servers.		application/database enumeration, and theft of files already trusted to MFT platforms.
--	--	--

3. Actor Identity and Aliases

Label	Notes
CLOP / CL0P / Cl0p / Cl0p	Ransomware family, extortion brand, and leak site identity.
CL0P^_-LEAKS	Data leak/shaming site brand used for victim pressure.
TA505	MITRE ATT&CK G0092; broad cybercriminal group active since at least 2014. Public reporting links TA505 to CLOP campaigns.
FIN11	Mandiant financial threat group; overlaps with TA505 and CLOP, but Mandiant cautions against treating FIN11 and TA505 as interchangeable.
Lace Tempest / DEV-0950 / Storm-0950	Microsoft-linked naming reported publicly for a CLOP ransomware affiliate associated with MOVEit/GoAnywhere-style extortion operations.
Graceful Spider, GOLD TAHOE, GOLD EVERGREEN, Hive0065, Chimborazo, Spandex Tempest	Public aliases/adjacent labels reported by government and vendor sources for TA505/CL0P-related activity.
UNC2546 / UNC2582 / UNC4857 / UNC5936	Mandiant uncategorized clusters associated with Accellion, MOVEit, Cleo, or related extortion activity before or during attribution refinement.

Analyst note: Use the label CLOP for the extortion brand/ransomware family. Use FIN11/TA505 only when the evidence supports the underlying actor cluster. A DLS post alone should not be converted into high-confidence FIN11 attribution without supporting infrastructure, malware, victimology, timing, or TTP overlap.

4. Motivation, Culture, and Operating Model

CLOP is a revenue-maximizing cybercriminal operation. Its behavior is consistent with an eCrime group that optimizes for repeatable monetization rather than stealthy espionage. The group's culture is pragmatic and coercive: steal sensitive data from high-value organizations, wait long enough to maximize the campaign's victim pool and negotiation leverage, then pressure executives through direct emails, leak-site posts, public countdowns, dedicated leak pages, or torrent distribution when conventional leak infrastructure is insufficient.

CLOP's operational evolution shows a move toward economies of scale. Earlier TA505/FIN11 activity relied heavily on broad phishing, malware loaders, reconnaissance, lateral movement, and eventual ransomware deployment. Later campaigns increasingly exploited concentrated trust points: enterprise MFT and business-application servers that hold large volumes of regulated, financial, HR, customer, legal, and partner data. This model reduces the need for noisy domain-wide ransomware deployment while preserving extortion pressure.

5. Historical Timeline

Period	Activity
2014+	TA505 active as a major cybercrime operator, known for high-volume phishing, malware distribution, financial fraud, and changing malware/tooling.
2019	CLOP observed as a CryptoMix-derived ransomware family. CISA notes it was used as a RaaS payload in large-scale spear-phishing

	campaigns with digitally signed binaries.
2019-2020	FIN11/TA505-linked phishing and malware chains used payloads such as Get2, SDBbot, FlawedGrace, ServHelper, Dridex, and others, with CLOP appearing as a final-stage ransomware/extortion payload.
2020	CLOP leak site activity becomes prominent; Unit 42 notes launch of CLOP leak site in March 2020.
Dec 2020-Jan 2021	Accellion FTA zero-day campaign: UNC2546 exploited Accellion FTA, deployed DEWMODE, and stole data; extortion followed through CLOP^_-LEAKS.
Jan-Feb 2023	GoAnywhere MFT zero-day CVE-2023-0669 exploited; CISA states CLOP claimed approximately 130 victims over roughly 10 days, with no identified lateral movement from GoAnywhere in available reporting.
May-Jun 2023	MOVEit Transfer CVE-2023-34362 mass exploitation. LEMURLOOT webshell deployed as human2.aspx/_human2.aspx; data stolen from MOVEit databases and storage. Mandiant merged UNC4857 into FIN11 based on overlaps.
Late 2024	Cleo Harmony/VLTrader/LexiCom exploitation involving CVE-2024-50623 and CVE-2024-55956. Rapid7/Huntress reported exploitation through autorun functionality and PowerShell/JAR follow-on activity. Google later linked a suspected FIN11 cluster to Cleo exploitation and GOLDVEIN/GOLDTOMB tooling.
2025	Google Threat Intelligence Group reported a large-scale Oracle E-Business Suite extortion campaign under the CLOP brand, involving executive extortion emails and possible zero-day exploitation of CVE-2025-61882.

6. Victimology and Targeting

CLOP does not appear to restrict targeting by sector in the way many espionage groups do. Its victimology is driven by where monetizable data resides and where internet-facing enterprise platforms create one-to-many compromise opportunities.

Common victim types:

Category	Why it matters to CLOP
Managed file transfer customers	MFT platforms store exactly the data organizations most need to protect: payroll, HR, financial files, customer exports, legal documents, healthcare data, and partner submissions.
Healthcare and life sciences	Sensitive PHI/PII increases regulatory pressure and ransom leverage.
Finance, insurance, and professional services	High-value client data, contract documents, regulated data, and reputational pressure.
Government and public sector	High publicity, sensitive citizen records, and third-party file transfer reliance.

Education	Large stores of PII, research, and distributed IT environments.
Manufacturing, logistics, and technology	Supply-chain files, intellectual property, partner data, and broad exposure to third-party MFT tools.
Large enterprises with global operations	More likely to run legacy MFT/business systems and have negotiation capacity.

Geography: Activity is global, with repeated reporting of victims in North America and Europe and public cases across many countries. The actor's monetization model favors organizations with high-value data and legal/reputational exposure rather than region-specific ideological targeting.

7. Mindset and Analyst Bottom Line

CLOP behaves like a criminal extortion enterprise that understands enterprise data workflows. The group identifies platforms that already centralize sensitive data, compromises them at scale, and weaponizes the victim's own data-handling trust chain. They do not need to encrypt a domain controller if the MFT appliance already contains enough regulated data to create board-level pressure.

Analyst bottom line: If your organization runs internet-facing MFT, EBS, or similar data-rich edge applications, CLOP should be modeled as an application-exploitation and data-theft threat first, and as an endpoint ransomware threat second. The most valuable detections are often in web access logs, application audit logs, application database records, unexpected child processes from service accounts, unusual archive creation, and outbound transfer volume from servers that normally only exchange data with known partners.

8. Tactics, Techniques, and Procedures

8.1. Initial Access

Technique	ATT&CK	CLOP relevance
Exploit Public-Facing Application	T1190	Core pattern in Accellion FTA, GoAnywhere MFT, MOVEit Transfer, Cleo, and Oracle EBS campaigns.
Spearphishing Attachment/Link	T1566.001 / T1566.002	Historic TA505/FIN11 campaigns used high-volume phishing, macro-enabled documents, links, and archives.
Valid Accounts	T1078	Post-exploitation user creation or stolen credentials may be used for access continuation; LEMURLOOT can create/delete a hard-coded user.

8.2. Execution

Technique	ATT&CK	CLOP relevance
Web Shell	T1505.003	DEWMODE on Accellion FTA, LEMURLOOT on MOVEit Transfer.
Command and Scripting Interpreter: PowerShell	T1059.001	Historic TA505 activity and Cleo post-exploitation PowerShell.
Windows Command Shell	T1059.003	Used for system enumeration and staging.
Java	T1059.007 / platform-specific scripting	Cleo and Oracle EBS reporting includes Java/JAR implant or loader behavior.

8.3. Persistence and Privilege

Technique	ATT&CK	CLOP relevance
Server Software Component: Web Shell	T1505.003	Webshells provide repeatable access to edge applications.
Create Account	T1136	LEMURLOOT includes capability to create/delete a particular user in MOVEit.
Scheduled/Autorun Execution	T1053 / T1547-adjacent	Cleo exploitation abused Autorun directory behavior to execute imported commands.

8.4. Defense Evasion

Technique	ATT&CK	CLOP relevance
Masquerading	T1036	human2.aspx/_human2.aspx masqueraded near legitimate MOVEit human.aspx.
Obfuscated/Compressed Files and Information	T1027	TA505 history includes packed malware, base64 PowerShell, and encrypted documents.
Impair Defenses	T1562	CLOP ransomware variants attempted to stop security and backup-related processes/services.
Virtualization/Sandbox Evasion	T1497	Unit 42 notes observed CLOP samples may avoid execution in virtual environments.

8.5. Discovery and Collection

Technique	ATT&CK	CLOP relevance
File and Directory Discovery	T1083	LEMURLOOT enumerates MOVEit files/folders; Cleo post-exploitation included host/system enumeration.
System Information Discovery	T1082	Rapid7 Cleo observations include systeminfo/whoami/wmic-style enumeration.
Permission Groups Discovery	T1069	Historic TA505 activity and Cleo observations include net group/domain-trust enumeration.
Data from Information Repositories	T1213	MFT/business-app databases and storage are primary data sources.
Data Staged	T1074	Stolen files may be staged/packaged before exfiltration.

8.6. Command and Control / Exfiltration

Technique	ATT&CK	CLOP relevance
Web Protocols	T1071.001	Webshell interaction over HTTP/S; X-

		siLock headers in MOVEit activity.
Ingress Tool Transfer	T1105	Follow-on payload/JAR retrieval in Cleo activity and historic TA505 loaders.
Exfiltration Over Web Service / C2 Channel	T1567 / T1041	Data theft from MFT servers and application stores.
Exfiltration Over Alternative Protocol	T1048	Possible depending on staging infrastructure; monitor cloud/object storage access as well.

8.7. Impact

Technique	ATT&CK	CLOP relevance
Data Encrypted for Impact	T1486	Classic CLOP ransomware variants encrypt files and append .clomp/.Clomp/.Cl0p-like extensions.
Data Destruction / Inhibit Recovery	T1485 / T1490	Ransomware variants have attempted to disrupt backups/security tools.
Data Extortion	T1657	Primary modern business model: leak-site pressure, executive emails, public disclosure threats.

9. Tooling and Malware

Tool/Malware	Role
CLOP ransomware	CryptoMix-derived ransomware used for file encryption and ransom notes; now less central in many modern CLOP-branded campaigns.
LEMURLOOT	MOVEit-specific C# webshell masquerading as human2.aspx/_human2.aspx; authenticates via X-siLock-Comment and uses X-siLock-Step headers for tasking.
DEWMODE	Accellion FTA webshell used for data theft.
SDBbot	TA505-associated malware observed in chains leading to CLOP deployment.
FlawedGrace / ServHelper / Get2 / Dridex / FlawedAmmyy	Historic TA505/FIN11 malware/tooling ecosystem.
Cobalt Strike, Mimikatz, AdFind, BloodHound, PowerSploit, Net	Common post-compromise tools associated with TA505/FIN11 operations; weak attribution indicators alone.
Java/JAR implants, GOLDVEIN/GOLDTOMB-style tooling	Reported in Cleo/Oracle EBS-era activity by Google/Mandiant; use campaign-specific validation before generalizing.

10. Infrastructure and Indicators

CLOP's most useful indicators are often behavioral rather than static. Many IPs/domains tied to mass exploitation age quickly, may be VPN/proxy infrastructure, and should be handled as short-lived watch indicators. Higher-confidence durable indicators include:

Indicator class	Examples / pattern
MOVEit webshell filenames	human2.aspx, _human2.aspx near MOVEit wwwroot; suspicious deviations from legitimate human.aspx.
MOVEit webshell headers	X-siLock-Comment, X-siLock-Step1, X-siLock-Step2, X-siLock-Step3.
Accellion webshell	DEWMODE; oauth.api eval/system webshell patterns in legacy FTA contexts.
Cleo exploitation artifacts	healthchecktemplate.txt / healthcheck.txt in autoruns; unexpected autorun file creation/deletion; PowerShell spawned by Java/Cleo process; suspicious JAR retrieval.
Ransomware artifacts	.cl0p/.Cl0p/.Cl0p extensions; ransom notes such as Cl0pReadMe.txt, README_README.txt, Cl0pReadMe.txt, READ_ME_!!!.TXT.
Extortion infrastructure	CL0P^_-LEAKS Tor/clearweb/torrent distribution; executive extortion emails from addresses publicly listed on the DLS in specific campaigns.
Edge-app data theft	Large downloads from MFT storage, unusual database queries, Azure Blob credential access from MOVEit settings, archive creation on application servers.

11. Detection Engineering

The detections below are designed as starting points. Tune paths, process names, indexes, and allowlists to local telemetry. Prioritize precision for externally exposed MFT servers and broaden to hunting mode across all edge applications.

11.1. Sigma: MOVEit LEMURLOOT Webshell File Artifact

```

title: Potential CLOP MOVEit LEMURLOOT Webshell File
id: 5c3a888e-51f2-4b8b-84a6-lemurl0ot-file
status: experimental
description: Detects suspicious MOVEit webshell filenames associated with CLOP/FIN11 MOVEit exploitation.
references:
  - https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a
  - https://cloud.google.com/blog/topics/threat-intelligence/zero-day-moveit-data-theft
logsource:
  product: windows
  category: file_event
detection:
  selection_name:
    TargetFilename|endswith:
      - '\\human2.aspx'
      - '\\_human2.aspx'
  selection_moveit_path:
    TargetFilename|contains:
      - '\\MOVEitTransfer\\'
      - '\\MOVEit Transfer\\'
      - '\\wwwroot\\'
  condition: selection_name and selection_moveit_path
fields:
  - TargetFilename
  - Image
  - User
  - CreationUtcTime

```

```

falsepositives:
  - Legitimate testing or manual IR collection using copied filenames
level: high
tags:
  - attack.t1190
  - attack.t1505.003
  - attack.t1036

```

11.2. Sigma: MOVEit X-siLock Header Interaction

```

title: Potential LEMURL00T X-siLock Header Webshell Interaction
id: 0e19b673-6401-4b3d-9b08-xsilock-header
status: experimental
description: Detects HTTP requests containing X-siLock headers used by LEMURL00T in MOVEit Transfer exploitation.
references:
  - https://cloud.google.com/blog/topics/threat-intelligence/zero-day-moveit-data-theft
  - https://www.rapid7.com/blog/post/2023/06/01/rapid7-observed-exploitation-of-critical-moveit-transfer-vulnerability/
logsource:
  category: webserver
detection:
  selection:
    cs-header|contains:
      - 'X-siLock-Comment'
      - 'X-siLock-Step1'
      - 'X-siLock-Step2'
      - 'X-siLock-Step3'
  condition: selection
fields:
  - c-ip
  - cs-method
  - cs-uri-stem
  - cs-header
  - sc-status
falsepositives:
  - Security testing using public CLOP/MOVEit emulation
level: critical
tags:
  - attack.t1190
  - attack.t1505.003
  - attack.t1071.001

```

11.3. Sigma: Cleo Autorun Exploitation and Post-Exploitation

```

title: Potential Cleo MFT Autorun Exploitation
id: 62203bc2-78fd-44a2-bc86-cleo-autorun
status: experimental
description: Detects suspicious file creation in Cleo autorun directories and command execution from Cleo/Java processes.
references:
  - https://www.rapid7.com/blog/post/2024/12/10/etr-widespread-exploitation-of-cleo-file-transfer-software-cve-2024-50623/
  - https://www.huntress.com/blog/threat-advisory-oh-no-cleo-cleo-software-actively-being-exploited-in-the-wild
logsource:
  product: windows
  category: file_event
detection:
  selection_path:
    TargetFilename|contains:
      - '\\autorun\\'
      - '\\autoruns\\'
      - '\\Cleo\\'
  selection_file:
    TargetFilename|endswith:
      - '\\healthchecktemplate.txt'

```

```

- '\\healthcheck.txt'
- '.ps1'
- '.jar'
condition: selection_path and selection_file
fields:
- TargetFilename
- Image
- User
falsepositives:
- Legitimate Cleo administrative autorun workflows; should be rare on internet-facing systems
level: high
tags:
- attack.t1190
- attack.t1059.001
- attack.t1105

```

11.4. Sigma: Ransomware Note or CLOP Extension

```

title: Potential CLOP Ransomware File Encryption Artifact
id: 9981fc0e-26d3-4d82-a2ad-clop-files
status: experimental
description: Detects CLOP ransom notes and encrypted file extension patterns.
references:
- https://unit42.paloaltonetworks.com/clop-ransomware/
logsource:
  product: windows
  category: file_event
detection:
  selection_note:
    TargetFilename|endswith:
      - '\\ClopReadMe.txt'
      - '\\ClOpReadMe.txt'
      - '\\README_README.txt'
      - '\\READ_ME_!!!.TXT'
  selection_ext:
    TargetFilename|endswith:
      - '.clop'
      - '.ClOp'
      - '.ClOp'
condition: selection_note or selection_ext
fields:
- TargetFilename
- Image
- User
falsepositives:
- Malware lab samples, documentation, or restored evidence directories
level: critical
tags:
- attack.t1486
- attack.t1657

```

11.5. YARA: CLOP Ransomware/Ransom Note Strings

```

rule Ransomware_CLOP_Strings_Generic {
  meta:
    description = "Generic string detection for CLOP ransomware/ransom-note artifacts; use for triage, not sole attribution"
    author = "Lost Boys Cyber"
    date = "2026-08-12"
    tlp = "CLEAR"
  strings:
    $brand1 = "Clop" nocase ascii wide
    $brand2 = "CL0P" nocase ascii wide
    $note1 = "ClopReadMe.txt" ascii wide
    $note2 = "ClOpReadMe.txt" ascii wide
    $note3 = "README_README.txt" ascii wide
    $note4 = "READ_ME_!!!.TXT" ascii wide

```

```
$leak = "CL0P^_-LEAKS" nocase ascii wide
condition:
  2 of ($brand*) or any of ($note*) or $leak
}
```

11.6. YARA: MOVEit LEMURLOOT ASP.NET Webshell Strings

```
rule Webshell_LEMURLOOT_MOVEit_XsiLock_Generic {
  meta:
    description = "Generic LEMURLOOT-style MOVEit webshell string detection"
    author = "Lost Boys Cyber"
    date = "2026-08-12"
    tlp = "CLEAR"
    reference = "https://cloud.google.com/blog/topics/threat-intelligence/zero-day-moveit-data-theft"
  strings:
    $h1 = "X-siLock-Comment" ascii wide
    $h2 = "X-siLock-Step1" ascii wide
    $h3 = "X-siLock-Step2" ascii wide
    $h4 = "X-siLock-Step3" ascii wide
    $db = "SystemSettings.DatabaseSettings" ascii wide
    $blob = "Azure" ascii wide
    $moveit = "MOVEit" ascii wide
  condition:
    filesize < 2MB and 3 of ($h*) and ( $db or $blob or $moveit )
}
```

12. Microsoft Defender XDR / KQL Hunt Queries

1.1. MOVEit LEMURLOOT file creation

```
DeviceFileEvents
| where Timestamp > ago(180d)
| where FileName in~ ("human2.aspx", "_human2.aspx")
|   or FolderPath has_any ("MOVEitTransfer", "MOVEit Transfer") and FileName endswith ".aspx"
| project Timestamp, DeviceName, InitiatingProcessAccountName, FileName, FolderPath,
  SHA256, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc
```

2.1. X-siLock header activity in proxy/WAF/web logs

```
// Adjust table names for Sentinel: CommonSecurityLog, W3CIISLog, AzureDiagnostics, or custom_CL.
union isfuzzy=true CommonSecurityLog, W3CIISLog, AzureDiagnostics
| where TimeGenerated > ago(180d)
| extend Raw = strcat(SourceIP, " ", RequestURL, " ", AdditionalExtensions, " ", csUserAgent, " ",
  Message)
| where Raw has_any ("X-siLock-Comment", "X-siLock-Step1", "X-siLock-Step2", "X-siLock-Step3")
| project TimeGenerated, DeviceVendor, DeviceProduct, SourceIP, DestinationIP, RequestURL, Raw
| order by TimeGenerated desc
```

3.1. Suspicious child processes from MFT/application servers

```
let MFTProcessHints = dynamic(["moveit", "cleo", "lexicom", "vltrader", "harmony", "java.exe",
  "w3wp.exe", "tomcat", "httpd", "nginx"]);
DeviceProcessEvents
| where Timestamp > ago(90d)
| where InitiatingProcessFileName has_any (MFTProcessHints)
| where FileName in~ ("powershell.exe", "pwsh.exe", "cmd.exe", "wscript.exe", "cscript.exe",
  "rundll32.exe", "msiexec.exe", "certutil.exe", "bitsadmin.exe", "curl.exe", "wget.exe", "whoami.exe",
  "systeminfo.exe", "nltest.exe", "net.exe", "wmic.exe")
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine,
  FileName, ProcessCommandLine, AccountName
| order by Timestamp desc
```

4.1. Cleo exploitation via autorun and PowerShell/JAR retrieval

```
DeviceFileEvents
| where Timestamp > ago(180d)
| where FolderPath has_any ("\\Cleo\\", "\\LexiCom\\", "\\VLTrader\\", "\\Harmony\\")
```

```

| where FolderPath has_any ("\\autorun\\", "\\autoruns\\") or FileName in~ ("healthchecktemplate.txt",
"healthcheck.txt") or FileName endswith ".jar"
| project Timestamp, DeviceName, ActionType, FileName, FolderPath, SHA256, InitiatingProcessCommandLine
| order by Timestamp desc
;
DeviceProcessEvents
| where Timestamp > ago(180d)
| where InitiatingProcessCommandLine has_any ("Cleo", "LexiCom", "VLTrader", "Harmony") or
InitiatingProcessFileName =~ "java.exe"
| where ProcessCommandLine has_any ("-NonInteractive", "Invoke-WebRequest",
"System.Net.Sockets.TcpClient", "DownloadString", "curl", "wget", ".jar")
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName,
ProcessCommandLine
| order by Timestamp desc

```

5.1. CLOP ransomware artifact hunt

```

DeviceFileEvents
| where Timestamp > ago(365d)
| where FileName in~ ("ClopReadMe.txt", "ClOpReadMe.txt", "README_README.txt", "READ_ME_!!!.TXT")
or FileName endswith ".clOp" or FileName endswith ".Clop" or FileName endswith ".ClOp"
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Count=count(),
SamplePaths=make_set(FolderPath, 20) by DeviceName, FileName, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by LastSeen desc

```

6.1. Edge application bulk exfiltration candidate hunt

```

let EdgeServers = DeviceInfo
| where Timestamp > ago(30d)
| where DeviceName has_any ("moveit", "mft", "cleo", "oracle", "ebs", "ftp", "sftp")
| summarize by DeviceName;
DeviceNetworkEvents
| where Timestamp > ago(90d)
| where DeviceName in (EdgeServers)
| where RemoteUrl !endswith ".microsoft.com" and RemoteUrl !endswith ".windowsupdate.com"
| summarize Connections=count(), RemoteIPs=dcount(RemoteIP), BytesOut=sum(SentBytes),
FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceName, RemoteUrl, RemoteIP,
InitiatingProcessFileName
| where BytesOut > 500000000 or Connections > 1000
| order by BytesOut desc

```

7. Splunk SPL Hunt Queries

1.1. MOVEit webshell and X-siLock headers

```

(index=web OR index=proxy OR index=iis) earliest=-180d
("X-siLock-Comment" OR "X-siLock-Step1" OR "X-siLock-Step2" OR "X-siLock-Step3" OR "human2.aspx" OR
 "_human2.aspx")
| table _time host src_ip dest_ip method uri status user_agent _raw
| sort - _time

```

2.1. Suspicious child process from web/MFT services

```

index=edr earliest=-90d
(parent_process_name IN ("w3wp.exe", "java.exe", "tomcat*.exe", "httpd.exe", "nginx.exe") OR
parent_process="*MOVEit*" OR parent_process="*Cleo*" OR parent_process="*LexiCom*" OR
parent_process="*VLTrader*" OR parent_process="*Harmony*")
(process_name IN
("powershell.exe", "pwsh.exe", "cmd.exe", "rundll32.exe", "msiexec.exe", "certutil.exe", "bitsadmin.exe", "cur
l.exe", "wget.exe", "whoami.exe", "systeminfo.exe", "nltest.exe", "net.exe", "wmic.exe"))
| table _time host user parent_process_name parent_process process_name process
| sort - _time

```

3.1. Cleo autorun artifacts

```

index=edr earliest=-180d
(file_path="*\\Cleo\\" OR file_path="*\\LexiCom\\" OR file_path="*\\VLTrader\\" OR file_path="*\\

```

```
\Harmony\\*)
(file_path="*\\autorun\\*" OR file_path="*\\autoruns\\*" OR file_name IN
("healthchecktemplate.txt","healthcheck.txt") OR file_name="*.jar")
| table _time host user action file_name file_path process_name process
| sort - _time
```

4.1. CLOP encryption artifacts

```
index=edr earliest=-365d
(file_name IN ("ClOpReadMe.txt","ClOpReadMe.txt","README_README.txt","READ_ME!!!.TXT") OR
file_name="*.clOp" OR file_name="*.ClOp" OR file_name="*.ClOp")
| stats min(_time) as first_seen max(_time) as last_seen count values(file_path) as paths
values(process_name) as processes by host file_name
| convert ctime(first_seen) ctime(last_seen)
| sort - last_seen
```

5. Suricata / Network Detection Starting Points

5.1. MOVEit LEMURLOOT X-siLock Header

```
alert http any any -> $HOME_NET any (msg:"LBC Possible CLOP MOVEit LEMURLOOT X-siLock Header";
flow:to_server,established; http_header; content:"X-siLock-"; nocase; classtype:web-application-attack;
sid:9001201; rev:1; metadata:attack_target Server, mitre_tactic_id TA0001, mitre_technique_id T1190;
reference:url,cloud.google.com/blog/topics/threat-intelligence/zero-day-moveit-data-theft;)
```

5.2. Suspicious MOVEit human2.aspx Request

```
alert http any any -> $HOME_NET any (msg:"LBC Possible CLOP MOVEit human2.aspx Webshell Request";
flow:to_server,established; http_uri; content:"human2.aspx"; nocase; classtype:web-application-attack;
sid:9001202; rev:1; metadata:attack_target Server, mitre_tactic_id TA0003, mitre_technique_id
T1505.003;)
```

6. Threat Hunting Playbooks

6.1. Hunt 1: Exposed MFT compromise triage

Hypothesis: An internet-facing MFT server was exploited, received a webshell/implant, and exfiltrated stored files without broad lateral movement.

Steps:

1. Inventory all MFT and data-transfer applications exposed to the internet: MOVEit, GoAnywhere, Cleo Harmony/VLTrader/LexiCom, Accellion FTA/kiteworks, Serv-U, SysAid, PaperCut, and similar systems.
2. Pull web logs, application audit logs, file integrity logs, EDR telemetry, and database access logs for at least 30 days before public vulnerability disclosure and 30 days after remediation.
3. Search for vendor-specific webshell markers: human2.aspx/_human2.aspx, X-siLock headers, DEWMODE/oauth.api, unexpected autorun files, unexpected JARs, and newly created app users.
4. Identify outbound connections from MFT servers to non-business destinations and large file egress by service accounts.
5. Review application database tables for unusual enumeration, archive/download jobs, and access to historical file records.
6. Preserve full disk images/log bundles before remediation when possible.

6.2. Hunt 2: Data theft without ransomware deployment

Hypothesis: CLOP-style actors stole data but did not deploy encryption malware.

Steps:

7. Identify systems with sensitive data and internet-facing access paths.
8. Hunt for archive creation, database dumps, and abnormal download/export volumes.
9. Correlate large outbound transfer spikes with suspicious web requests and service-account process execution.
10. Review DLP/cloud storage logs for bulk reads or credential use from edge servers.

11. Search executive mailboxes and abuse mailboxes for delayed extortion communications.

6.3. Hunt 3: Classic TA505/FIN11 intrusion chain leading to CLOP

Hypothesis: A phishing or loader-based intrusion established access before ransomware/extortion.

Steps:

12. Search email telemetry for high-volume lures, macro documents, archive attachments, ISO/LNK chains, and external links.
13. Hunt endpoints for Get2/SDBbot/FlawedGrace/ServHelper/Dridex/FlawedAmmyy family detections and suspicious msixexec/rundll32/PowerShell chains.
14. Look for AdFind/BloodHound/Mimikatz/PowerSploit and domain discovery commands.
15. Review backup/security process termination and Defender/EDR policy tampering.
16. Search for CLOP ransom notes and extensions.

6.4. Hunt 4: Cleo exploitation-focused hunt

Hypothesis: Cleo file-transfer servers were exploited through vulnerable import/autorun behavior.

Steps:

17. Identify all Cleo products and versions; prioritize versions before 5.8.0.24 for CVE-2024-55956 review.
18. Review hosts subdirectories and autorun/autoruns folders for healthchecktemplate.txt, healthcheck.txt, unexpected PowerShell, or JAR files.
19. Query process telemetry for Java/Cleo spawning PowerShell with -NonInteractive, Invoke-WebRequest, System.Net.Sockets.TcpClient, curl, wget, or encoded commands.
20. Review network logs for outbound JAR retrieval and suspicious destination IPs shortly after autorun activity.
21. Compare file transfer logs against known business partners and expected schedules.

6.5. Hunt 5: Oracle EBS extortion campaign review

Hypothesis: Oracle EBS was exploited and sensitive application data was stolen before extortion emails.

Steps:

22. Verify all Oracle Critical Patch Updates and emergency patches were applied; confirm EBS exposure paths.
23. Review web/app-server logs for anomalous unauthenticated requests, Java loader activity, and unexpected child processes.
24. Search for unusual archive/export creation and large outbound transfers from EBS tiers.
25. Review database audit logs for abnormal query volume or access outside normal service-account patterns.
26. Correlate executive extortion emails with EBS file listings or data samples provided by actors.

7. Priority Defensive Controls

Priority	Control	Why it matters
1	Maintain authoritative internet-facing application inventory.	CLOP repeatedly targets exposed edge data applications.
2	Patch MFT/business applications under emergency SLAs.	Many campaigns begin as zero-days or near-zero-day exploitation; slow patch windows increase exposure.
3	Restrict MFT/admin interfaces by VPN,	Reduces mass exploitation surface.

	allowlists, or private access.	
4	Enable detailed web, app, database, and file-access logging.	Data-theft campaigns often leave evidence outside endpoint telemetry.
5	Monitor abnormal outbound transfer volume from MFT/EBS servers.	Exfiltration is the monetization step.
6	Deploy file integrity monitoring on application webroots and autorun directories.	Detects webshell/implant placement.
7	Separate MFT storage from broad internal trust; minimize retained files.	Reduces blast radius if the app is compromised.
8	Enforce egress controls from edge servers.	MFT servers should not freely contact arbitrary hosts.
9	Build extortion-response procedures for executives/legal/PR.	CLOP often delays contact and targets executives.
10	Test recovery and encryption-ransomware detections anyway.	Classic CLOP encryption remains possible in some intrusions.

8. Incident Response Guidance

If CLOP-style compromise is suspected:

27. Isolate but preserve the affected MFT/business application server.
28. Collect web logs, app logs, database logs, storage access logs, EDR telemetry, memory where possible, and full file listings of application directories.
29. Search for campaign markers: LEMURLOOT, DEWMODE, X-siLock headers, human2.aspx, Cleo autorun artifacts, unexpected Java/JAR loaders, and abnormal child processes.
30. Determine data exposure scope from application database records, storage logs, download records, and outbound transfer telemetry.
31. Rotate application secrets and cloud storage credentials; LEMURLOOT was reported capable of stealing Azure Blob configuration/credentials from MOVEit settings.
32. Patch/rebuild from trusted media where feasible; do not simply delete the webshell and return to service.
33. Prepare legal/regulatory notifications based on confirmed data categories.
34. Monitor CLOP DLS/open-source reporting and executive inboxes for delayed extortion communications.
35. Do not rely on absence of ransomware encryption as evidence of no incident.

9. Attribution Caveats

- CLOP branding does not automatically equal FIN11/TA505 for every event. Treat DLS claims as extortion evidence, not complete attribution.
- Commodity tools such as Cobalt Strike, Mimikatz, AdFind, or PowerShell are weak actor indicators alone.
- Historic TA505 phishing TTPs remain relevant, but the modern CLOP risk profile is dominated by edge application exploitation and data theft.
- IP indicators from mass exploitation windows are often low-durability; use them as scoped investigation pivots, not long-term blocklist truth.
- Some public sources discuss future/current campaigns with evolving attribution; validate against primary vendor/government reporting before operationalizing.

10. Source Review and Reliability

Source	Reliability	Key use in this profile
CISA/FBI AA23-158A StopRansomware advisory	High	MOVEit exploitation, LEMURLOOT, TA505/CLOP background, GoAnywhere and Accellion campaign summary.
MITRE ATT&CK G0092	High	TA505 aliases, ATT&CK technique baseline, software associations.
Canadian Centre for Cyber Security TA505/CLOP profile	High	Actor motivation, alias set, CIS/Russian-speaking assessment, forward-looking threat assessment.
Google Cloud / Mandiant MOVEit report	High	UNC4857 to FIN11 merger, LEMURLOOT behavior, X-siLock headers, human2.aspx, Azure credential theft capability.
Google Cloud / Mandiant FIN11 report	High	FIN11 phishing history, monetization evolution, caution against conflating FIN11 and TA505.
Google Cloud / Mandiant Accellion report	High	DEWMODE, UNC2546/UNC2582, CLOP leak-site extortion linkage.
Google Cloud / Mandiant Oracle EBS report	High for reported campaign details; medium for final attribution breadth	2025 CLOP-branded Oracle EBS extortion campaign and warning that CLOP branding may involve more than one actor cluster.
Rapid7 MOVEit and Cleo reporting	High	Observed exploitation, affected versions, webshell artifacts, Cleo command observations and detection ideas.
Huntress Cleo advisory	High	Cleo exploit mechanics, autorun artifacts, vulnerable versions, mitigation recommendations.
Unit 42 Clop threat assessment	High	CLOP ransomware behavior, leak site, ransom notes/extensions, process/service termination.

11. References

- CISA/FBI: #StopRansomware: CLOP Ransomware Gang Exploits CVE-2023-34362 MOVEit Vulnerability: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a>
- MITRE ATT&CK: TA505 G0092: <https://attack.mitre.org/groups/G0092/>
- Canadian Centre for Cyber Security: Profile: TA505 / CLOP ransomware: <https://www.cyber.gc.ca/en/guidance/profile-ta505-cl0p-ransomware>
- Google Cloud / Mandiant: Zero-Day Vulnerability in MOVEit Transfer Exploited for Data Theft: <https://cloud.google.com/blog/topics/threat-intelligence/zero-day-moveit-data-theft>
- Google Cloud / Mandiant: FIN11: Widespread Email Campaigns as Precursor for Ransomware and Data Theft: <https://cloud.google.com/blog/topics/threat-intelligence/fin11-email-campaigns-precursor-for-ransomware-data-theft>
- Google Cloud / Mandiant: Threat Actors Exploit Accellion FTA for Data Theft and Extortion: <https://cloud.google.com/blog/topics/threat-intelligence/accellion-fta-exploited-for-data-theft-and-extortion>

- Google Cloud / Mandiant: Oracle E-Business Suite Zero-Day Exploited in Widespread Extortion Campaign: <https://cloud.google.com/blog/topics/threat-intelligence/oracle-ebusiness-suite-zero-day-exploitation>
- Unit 42: Threat Assessment: Clop Ransomware: <https://unit42.paloaltonetworks.com/clop-ransomware/>
- Rapid7: Observed Exploitation of MOVEit Transfer Vulnerability CVE-2023-34362: <https://www.rapid7.com/blog/post/2023/06/01/rapid7-observed-exploitation-of-critical-moveit-transfer-vulnerability/>
- Rapid7: Widespread Exploitation of Cleo File Transfer Software: <https://www.rapid7.com/blog/post/2024/12/10/etr-widespread-exploitation-of-cleo-file-transfer-software-cve-2024-50623/>
- Huntress: Cleo Software Actively Being Exploited in the Wild: <https://www.huntress.com/blog/threat-advisory-oh-no-cleo-cleo-software-actively-being-exploited-in-the-wild>